

duckexchange

web · medium · A tenant document API with a gRPC transcoding authorization bypass.

Category: Web

Difficulty: Medium

Flag format: `duck{...}`

Estimated time: 30–60 minutes

Brief

DuckExchange is the delivery-review portal used by Legal Operations and the incident-response team. Each customer has its own workspace, and analysts can review the delivery queue for their tenant. External packets may be held for ownership review before they can be released.

An incident packet is stuck in that queue. Find it and recover the flag.

Goal

Investigate DuckExchange and recover the challenge flag.

Setup

For a hosted instance, use the challenge URL provided by the organizer:

```
http://HOST:4000
```

For a local copy, start the lab from this directory:

```
docker compose up -d
```

Then open `http://127.0.0.1:4000`.

Create an analyst account, then sign in with the credentials you registered.

Passwords must be at least eight characters and contain an uppercase letter, a lowercase letter, a number, and a special character.

You only need the challenge URL. A browser, Burp Suite, or `curl` is enough; source code and access to the host are not required.

Reset

For a hosted instance, ask the organizer to reset the challenge. For an authorized local deployment, reset it with:

```
docker compose down -v  
docker compose up -d --build
```

Do not edit the application source or database files by hand.

Rules

- Test only the assigned challenge instance.
- Do not attack the host, Docker daemon, other containers, or external systems.
- Do not run denial-of-service or destructive tests.
- Keep any recovered flag and account credentials private.